

CISSP Manager-Mindset Guide

DOMAIN 5 | IDENTITY AND ACCESS MANAGEMENT

Identity • Authentication • Authorization • Federation • Lifecycle

PURPOSE A decision-oriented guide to ensuring the right subjects receive the right access to the right resources, for the right purpose and time, with accountable evidence.

Aligned to the ISC2 CISSP Certification Exam Outline effective April 15, 2024
Domain weight: 13%

How to Use This Guide

Domain 5 questions frequently mix several distinct steps: establishing an identity, presenting an identifier, authenticating, authorizing an action, and recording accountability. Separate those steps first, then look for business ownership, least privilege, lifecycle timing, and evidence.

DEFAULT DECISION LENS Establish identity with confidence, obtain owner-approved access based on business need, enforce least privilege and separation of duties, monitor use, review continuously, and revoke promptly when need changes.

The Domain 5 Manager Mindset

- Access is a business decision implemented by IAM—not an entitlement created by technical capability.
- Identity proofing precedes credential issuance; authentication precedes authorization; accounting supports accountability.
- Use roles and attributes to scale policy, but retain owner approval and manage exceptions.
- Prefer short-lived, just-in-time privilege over broad standing access.
- Federation extends trust across administrative boundaries; validate the identity provider, assertions, mappings, and lifecycle.
- SSO improves usability and centralized control but increases concentration and session risk.
- Joiner, mover, and leaver processes must remove obsolete access as quickly as they add required access.
- Non-human identities require owners, inventories, least privilege, secret rotation, monitoring, and retirement.

Domain 5 Roadmap

Objective	Focus	Primary decision question
5.1	Access to physical and logical assets	Which subjects should access which resources and under what conditions?
5.2	Identification and authentication strategy	How is identity established and authenticated with appropriate assurance?
5.3	Third-party federation	How is identity trust extended across on-premises, cloud, and hybrid boundaries?
5.4	Authorization mechanisms	Which access model and enforcement architecture best fit the business policy?
5.5	Provisioning lifecycle	How is access approved, changed, reviewed, elevated, and revoked?
5.6	Authentication systems	How are authentication mechanisms implemented securely, resiliently, and accountably?

5.1 Control Physical and Logical Access

Subjects, Objects, and Access Rules

Easy definition: A subject is an active entity requesting access; an object is a resource being accessed; an access rule determines which operation is allowed under defined conditions.

When it matters: Users, services, devices, files, databases, applications, APIs, facilities, and cloud resources.

THINK LIKE A MANAGER Define access from business purpose, ownership, sensitivity, risk, and context; deny by default and make exceptions explicit and reviewable.

EXAM TRAPS

- Calling a person the only possible subject.
- Treating authentication as permission to every object.
- Granting access based on location or network membership alone.
- Ignoring actions such as read, write, execute, approve, administer, and delegate.

QUICK DISTINCTION Authentication establishes confidence in the subject; authorization determines permitted operations on an object.

Physical and Logical Access Convergence

Easy definition: Physical and logical IAM coordinate identity and policy across facilities, systems, devices, applications, and services.

When it matters: Badges, smart cards, workstation login, data centers, visitor access, remote work, and termination.

THINK LIKE A MANAGER Use an authoritative identity lifecycle and consistent policy while preventing one credential or system failure from creating unacceptable combined impact.

EXAM TRAPS

- Assuming a valid badge proves current logical authorization.
- Issuing physical and logical credentials through disconnected processes.
- Failing to revoke both types during termination.
- Combining access systems without privacy, availability, or concentration-risk review.

QUICK DISTINCTION Convergence improves consistency and correlation; it also concentrates identity, privacy, and availability risk.

Least Privilege, Need-to-Know, and Default Deny

Easy definition: Least privilege limits capability, need-to-know limits information, and default deny blocks access unless it is explicitly allowed.

When it matters: Every access model, privileged administration, data access, network policy, and facility security.

THINK LIKE A MANAGER Grant the smallest approved access for the shortest needed time and require reauthorization when role, resource, or risk changes.

EXAM TRAPS

- Granting broad access to reduce support calls.
- Using least privilege only for administrators.
- Keeping access after a project ends.
- Assuming group membership remains appropriate forever.
- Treating default deny as a substitute for clear business policy.

QUICK DISTINCTION Least privilege asks “how much capability?” Need-to-know asks “which information?” Default deny defines the starting decision.

5.2 Identification and Authentication Strategy

Identity Proofing, Identification, Authentication, Authorization, and Accounting

Easy definition: Proofing establishes a real-world or organizational identity; identification claims an identity; authentication verifies the claim; authorization grants permitted actions; accounting records activity.

When it matters: Onboarding, logins, access decisions, federation, audits, and investigations.

THINK LIKE A MANAGER Match proofing and authentication assurance to risk, then enforce owner-approved authorization and preserve reliable accountability.

EXAM TRAPS

- Confusing a username with authentication.
- Issuing credentials before proofing identity.
- Treating successful authentication as blanket authorization.
- Collecting logs that cannot be tied reliably to an individual or service.

QUICK DISTINCTION Proof who you are → claim an identifier → verify the claim → decide access → record accountable use.

Identity Decision Sequence

Stage	Question	Typical evidence or control
Proofing	Who is this entity in the real world or organization?	Documents, authoritative records, sponsor validation
Identification	Which identity is being claimed?	Username, subject ID, certificate name
Authentication	How confidently is the claim verified?	Password, token, biometric, certificate
Authorization	What may the authenticated subject do?	Role, attribute, rule, policy decision
Accounting	What did the subject do and when?	Logs, session records, approvals, transactions

Authentication Factors and MFA

Easy definition: Factors are something you know, have, are, do, or somewhere you are; MFA uses two or more different factor categories.

When it matters: Interactive login, remote access, privileged operations, step-up authentication, and transaction approval.

THINK LIKE A MANAGER Choose phishing-resistant, usable factors proportional to risk and design secure enrollment, recovery, revocation, and fallback.

EXAM TRAPS

- Calling password plus PIN MFA; both are knowledge factors.
- Counting two passwords as two factors.
- Ignoring weak recovery questions or help-desk reset.
- Assuming biometrics are secret or easily changed after compromise.
- Treating SMS as equal to phishing-resistant authenticators.

QUICK DISTINCTION Two-step verification may use two checks of one factor; MFA requires different factor categories.

Passwords, Passphrases, and Stored Verifiers

Easy definition: Password systems should support long unique secrets, block known-compromised values, rate-limit guessing, and store salted, slow, adaptive hashes rather than recoverable plaintext.

When it matters: Workforce login, local accounts, applications, recovery, and credential policy.

THINK LIKE A MANAGER Reduce password burden with password managers, SSO, and stronger authenticators; secure the full lifecycle rather than relying on frequent arbitrary changes.

EXAM TRAPS

- Storing encrypted passwords when verification does not require recovery.
- Using fast unsalted hashes.
- Forcing predictable periodic changes without evidence of compromise.
- Applying complexity rules that encourage reuse and patterns.
- Ignoring default, embedded, and service-account passwords.

QUICK DISTINCTION Salt defeats precomputed hash reuse; a pepper is a separate secret added by the system; adaptive hashing intentionally increases guessing cost.

Tokens, Smart Cards, OTP, and Passwordless Authentication

Easy definition: Possession authenticators include hardware or software tokens, smart cards, one-time passwords, and cryptographic passkeys; passwordless systems authenticate without a memorized shared secret.

When it matters: MFA, workforce identity, privileged access, mobile access, and phishing resistance.

THINK LIKE A MANAGER Favor cryptographic, verifier-bound authenticators for higher risk and protect issuance, activation, device binding, backup, and revocation.

EXAM TRAPS

- Assuming all tokens resist phishing.
- Calling a device possession factor when an attacker can clone or remotely use it easily.
- Using push approval without number matching or context, enabling fatigue attacks.
- Forgetting lost-device and token-replacement processes.
- Assuming passwordless means single-factor or risk-free.

QUICK DISTINCTION OTP can be phished and replayed briefly; cryptographic passkeys/FIDO authenticate the legitimate service and resist credential replay.

Biometrics and Performance Metrics

Easy definition: Biometrics authenticate using measurable physical or behavioral traits; systems balance false acceptance, false rejection, enrollment failure, usability, privacy, and spoof resistance.

When it matters: Devices, facilities, high-assurance access, continuous authentication, and multimodal systems.

THINK LIKE A MANAGER Use biometrics as one factor with liveness and secure template protection; set thresholds from risk and provide governed alternatives.

EXAM TRAPS

- Treating a biometric as a secret that can be reissued.
- Choosing the lowest crossover error rate without considering business impact.
- Confusing false acceptance with false rejection.
- Ignoring accessibility, bias, privacy, hygiene, and coercion.
- Storing raw biometric images unnecessarily.

QUICK DISTINCTION FAR admits an unauthorized person; FRR rejects an authorized person; CER/EER is where the two rates are equal—useful for comparison, not the only business criterion.

Groups, Roles, and Identity Attributes

Easy definition: Groups collect identities for administration; roles represent job functions and permissions; attributes describe subjects, resources, actions, and context for policy decisions.

When it matters: Enterprise directories, RBAC, ABAC, cloud IAM, federation, and access reviews.

THINK LIKE A MANAGER Design stable business roles and governed attributes, prevent nested-group sprawl, and ensure mappings have owners and periodic review.

EXAM TRAPS

- Using technical groups as business roles without ownership.
- Creating a role for every individual or exception.
- Allowing nested groups to hide effective access.
- Trusting federation attributes without validating source and meaning.
- Failing to remove stale role assignments during transfers.

QUICK DISTINCTION Group is an administrative collection; role represents business function; attribute is a characteristic used in policy.

Session Management

Easy definition: Session management securely creates, binds, maintains, times out, reauthenticates, and terminates authenticated interactions.

When it matters: Web applications, SSO, remote access, privileged sessions, APIs, and mobile applications.

THINK LIKE A MANAGER Limit session duration and scope based on risk, protect tokens, detect anomalies, require step-up for sensitive actions, and provide reliable revocation.

EXAM TRAPS

- Assuming authentication risk ends after login.
- Using predictable or exposed session identifiers.
- Allowing indefinite sessions after role or employment change.
- Failing to invalidate sessions after password reset or compromise.
- Using inactivity timeout as the only session control.

QUICK DISTINCTION Authentication starts a session; session management maintains assurance and authorization throughout its lifetime.

Credential Management Systems and Vaults

Easy definition: Credential-management systems issue, store, rotate, retrieve, inject, and revoke passwords, keys, certificates, and secrets under policy and audit.

When it matters: Privileged accounts, service accounts, applications, DevOps, cloud, databases, and emergency access.

THINK LIKE A MANAGER Remove secrets from people and code where possible, centralize lifecycle controls with strong resilience, and make access time-bound and attributable.

EXAM TRAPS

- Treating a vault as permission to share one administrator account.
- Storing secrets centrally without high availability and recovery.
- Checking out passwords without automatic rotation.
- Embedding vault credentials in code.
- Ignoring certificates, API keys, tokens, and machine identities.

QUICK DISTINCTION A password manager helps users manage credentials; an enterprise vault governs privileged and machine secrets with policy, rotation, injection, and audit.

Single Sign-On

Easy definition: SSO lets one authenticated session access multiple services through centralized identity and trust relationships.

When it matters: Workforce applications, SaaS, portals, federation, and user experience.

THINK LIKE A MANAGER Use strong primary authentication, protect the identity provider and session, minimize token scope and lifetime, and preserve emergency access and resilience.

EXAM TRAPS

- Assuming SSO means one shared password copied to every application.
- Ignoring the identity provider as a high-value concentration point.
- Allowing application sessions to outlive employment or central revocation.
- Confusing SSO with federation.
- Using SSO without consistent authorization at each relying service.

QUICK DISTINCTION SSO is the user experience of one login across services; federation is the trust arrangement that may enable SSO across domains.

Just-in-Time Access and Step-Up Authentication

Easy definition: JIT grants access only when needed for a limited period; step-up requires stronger authentication when context or action risk increases.

When it matters: Privileged administration, cloud, production support, sensitive transactions, and emergency access.

THINK LIKE A MANAGER Replace standing privilege with approved, time-bound elevation and require stronger proof at the moment of sensitive action.

EXAM TRAPS

- Leaving elevated sessions active after the task.
- Granting JIT access without approval or logging.
- Using step-up authentication as a substitute for authorization.
- Failing to define emergency or break-glass procedures.
- Assuming temporary access cannot be abused.

QUICK DISTINCTION JIT changes when access exists; step-up changes authentication strength; both should preserve least privilege and accountability.

5.3 Federated Identity with Third-Party Services

Federated Identity Fundamentals

Easy definition: Federation establishes trust so one identity provider authenticates subjects and sends assertions or tokens that relying parties use for access decisions.

When it matters: Business partners, SaaS, cloud, customer identity, mergers, and cross-domain access.

THINK LIKE A MANAGER Define trust, assurance, attributes, token audience and lifetime, provisioning and deprovisioning, incident response, and termination before enabling federation.

EXAM TRAPS

- Trusting every attribute the identity provider can send.
- Allowing a token intended for one service to be used at another.
- Confusing authentication assertion with final authorization.
- Ignoring signing-key rotation, metadata, clock synchronization, and revocation.
- Ending a business relationship without removing federation trust.

QUICK DISTINCTION Identity provider authenticates and issues assertions; service provider/relying party validates them and makes its own authorization decision.

SAML, OAuth 2.0, and OpenID Connect

Easy definition: SAML commonly exchanges XML authentication assertions for enterprise browser SSO; OAuth delegates authorization to APIs; OpenID Connect adds an identity layer and ID token to OAuth 2.0.

When it matters: SaaS SSO, mobile and web applications, API authorization, and third-party delegated access.

THINK LIKE A MANAGER Select the protocol for the actual objective, restrict clients, redirect URIs, scopes, audience, tokens, and consent, and validate every token properly.

EXAM TRAPS

- Calling OAuth an authentication protocol by itself.
- Using an access token as proof of user identity.
- Failing to validate issuer, audience, signature, expiration, and nonce/state where applicable.
- Granting broad scopes for convenience.
- Confusing a SAML assertion with an OAuth access token.

QUICK DISTINCTION SAML = authentication assertions/enterprise SSO. OAuth = delegated authorization. OIDC = authentication identity layer built on OAuth.

On-Premises, Cloud, and Hybrid Federation

Easy definition: Federation may join on-premises directories, cloud identity services, partners, and applications through synchronization, agents, trusts, or token services.

When it matters: Hybrid workforce, SaaS, cloud migration, mergers, and legacy applications.

THINK LIKE A MANAGER Choose authoritative sources, minimize synchronized secrets and attributes, design failure behavior, and ensure lifecycle changes propagate quickly across environments.

EXAM TRAPS

- Synchronizing more personal or credential data than necessary.
- Allowing old on-premises accounts to remain active after cloud migration.
- Assuming cloud availability resolves on-premises dependency.
- Creating circular or unclear sources of authority.
- Ignoring legacy protocols that bypass federation and MFA.

QUICK DISTINCTION Synchronization copies selected identity data; federation exchanges trust assertions without requiring every relying party to store the original credential.

5.4 Authorization Mechanisms

Discretionary Access Control

Easy definition: DAC lets an object owner or authorized delegate decide who receives access, commonly through ACLs.

When it matters: File systems, collaboration, user-owned resources, and flexible commercial environments.

THINK LIKE A MANAGER Use DAC where owner flexibility is appropriate, but constrain delegation, inheritance, oversharing, and orphaned permissions through policy and review.

EXAM TRAPS

- Assuming discretion means no organizational policy.
- Allowing users to share sensitive data externally without controls.
- Ignoring inherited ACLs and nested groups.
- Confusing DAC with role-based access.

QUICK DISTINCTION DAC decisions are owner-controlled; MAC decisions are centrally enforced through labels and clearances.

Mandatory Access Control

Easy definition: MAC centrally enforces access using security labels, classifications, clearances, and formal policy that ordinary users cannot override.

When it matters: Multilevel government systems, high-assurance environments, and strict information-flow control.

THINK LIKE A MANAGER Use MAC where centrally enforced policy and labeled information flows justify reduced owner discretion and greater complexity.

EXAM TRAPS

- Calling operating-system administrator permissions automatically MAC.
- Assuming clearance alone grants access without need-to-know.
- Confusing mandatory policy with a mandatory company rule.
- Ignoring trusted subjects and controlled downgrading.

QUICK DISTINCTION MAC = system-enforced labels and policy; DAC = owner discretion; both still require authentication and administration.

Role-Based Access Control

Easy definition: RBAC assigns permissions to roles and users to roles, scaling access around job functions and supporting least privilege and separation of duties.

When it matters: Enterprises, applications, cloud, databases, and regulatory environments.

THINK LIKE A MANAGER Build roles from stable business functions, assign owners, manage toxic combinations, and use governed exceptions rather than endless role creation.

EXAM TRAPS

- Creating a unique role for every user.
- Confusing role with directory group.
- Ignoring role explosion and inherited privilege.
- Keeping both old and new roles after transfer.
- Assuming RBAC handles every contextual condition.

QUICK DISTINCTION RBAC answers “what does this job function need?” ABAC adds dynamic decisions from multiple attributes and context.

Rule-Based Access Control

Easy definition: Rule-based access applies system-wide rules—often if/then conditions—such as firewall rules, time restrictions, or mandatory policy conditions.

When it matters: Network controls, applications, data filters, and contextual restrictions.

THINK LIKE A MANAGER Keep rules traceable to policy, ordered correctly, tested for conflicts, and reviewed throughout change.

EXAM TRAPS

- Confusing rule-based access with RBAC because both use “rules.”
- Allowing broad rules to shadow specific restrictions.
- Accumulating temporary rules indefinitely.
- Ignoring implicit deny and rule order.

QUICK DISTINCTION Rule-based = system evaluates rules and conditions; role-based = permissions are associated with job roles.

Attribute-Based and Risk-Based Access Control

Easy definition: ABAC evaluates subject, object, action, and environmental attributes; risk-based access adds dynamic risk signals such as device posture, location, behavior, and threat.

When it matters: Zero trust, cloud, APIs, fine-grained data access, remote work, and adaptive authentication.

THINK LIKE A MANAGER Use authoritative attributes, understandable policies, privacy-aware signals, explainable decisions, and safe fallback when context services fail.

EXAM TRAPS

- Trusting user-supplied attributes.
- Creating policies too complex to test or audit.
- Treating location as proof of identity.
- Blocking legitimate users without remediation or exception paths.
- Using opaque risk scores with no owner or threshold governance.

QUICK DISTINCTION ABAC evaluates attributes; risk-based access emphasizes dynamic likelihood and context. Risk may be one of the ABAC inputs.

Policy Decision and Enforcement Points

Easy definition: A policy decision point evaluates policy and context; a policy enforcement point intercepts a request and allows or blocks it; supporting information points provide attributes and administration defines policy.

When it matters: Zero trust, software-defined perimeters, APIs, cloud, and modern authorization architecture.

THINK LIKE A MANAGER Protect the decision, enforcement, attribute, and administration functions as a system; define failure behavior and prevent bypass paths.

EXAM TRAPS

- Putting policy logic only in the enforcement device.
- Allowing requests around the PEP.
- Treating stale attributes as current truth.
- Failing open without business and safety analysis.
- Ignoring availability of the PDP.

QUICK DISTINCTION PDP decides; PEP enforces; PIP supplies attributes; PAP manages policy.

Authorization Model Comparison

Model	Decision basis	Manager cue
DAC	Owner discretion / ACL	Flexible but prone to oversharing and inheritance complexity
MAC	Central labels and clearances	Strong information-flow policy; users cannot override
RBAC	Job role	Scalable business permissions and separation of duties
Rule-based	System rules and conditions	Consistent global conditions; manage order and exceptions
ABAC	Subject/object/action/environment attributes	Fine-grained and dynamic; demands trustworthy attributes
Risk-based	Current risk and context	Adaptive decisions; thresholds and remediation must be governed

5.5 Identity and Access Provisioning Lifecycle

Joiner, Mover, and Leaver Processes

Easy definition: The identity lifecycle creates approved identities and access, adjusts them when responsibilities change, and promptly removes access when employment or need ends.

When it matters: Employees, contractors, vendors, students, customers, services, and devices.

THINK LIKE A MANAGER Use authoritative events, owner-approved role access, automated timely changes, reconciliation, and evidence; movers are often the greatest accumulation risk.

EXAM TRAPS

- Adding new mover access without removing old access.
- Waiting for account inactivity to identify termination.
- Disabling one directory account while cloud, local, badge, token, and vendor accounts remain.
- Provisioning contractors without expiration dates.
- Deleting accounts before preserving required records and ownership transfer.

QUICK DISTINCTION Joiner adds justified access; mover revalidates and replaces access; leaver revokes access and transfers ownership immediately according to risk.

Provisioning, Deprovisioning, and Reconciliation

Easy definition: Provisioning creates identities and access from approved requests; deprovisioning removes them; reconciliation compares intended access with actual target-system state.

When it matters: Directories, SaaS, applications, databases, cloud, physical access, and automation.

THINK LIKE A MANAGER Automate low-risk standard access with approval and validation, but verify target completion and investigate differences between source and actual access.

EXAM TRAPS

- Assuming a workflow success message proves access changed in the target.
- Deleting rather than disabling when audit records must remain.
- Failing to remove active sessions and tokens.
- Ignoring manually created local accounts.
- Granting access from copied user profiles without owner review.

QUICK DISTINCTION Deprovisioning initiates removal; reconciliation confirms intended and actual states match.

Access Reviews and Recertification

Easy definition: Access reviews require accountable owners or managers to verify that current access remains necessary, appropriate, and free of prohibited combinations.

When it matters: Privileged access, sensitive data, regulatory compliance, contractors, applications, and role assignments.

THINK LIKE A MANAGER Provide reviewers understandable effective access, business context, last use, risk,

and conflicts; require action and verify revocation.

EXAM TRAPS

- Sending unreadable permission dumps to managers.
- Treating no response as approval.
- Reviewing direct grants but not groups, roles, inheritance, or federation.
- Recording certification without removing rejected access.
- Using annual review as a substitute for event-driven deprovisioning.

QUICK DISTINCTION Review asks whether access is still appropriate; reconciliation verifies systems match the approved result.

Privilege Elevation and PAM

Easy definition: Privilege elevation grants higher capability for approved tasks; privileged access management controls vaulting, approval, JIT elevation, session isolation, recording, and rotation.

When it matters: Administrators, cloud roles, databases, network devices, emergency access, and production support.

THINK LIKE A MANAGER Separate normal and privileged identities, remove standing rights, require task-based elevation, monitor sessions, and maintain governed break-glass access.

EXAM TRAPS

- Using one administrator account for daily email and privileged work.
- Recording sessions without protecting or reviewing recordings.
- Requiring approval from the same person performing the action.
- Leaving emergency accounts untested or unmonitored.
- Assuming sudo alone is a complete PAM program.

QUICK DISTINCTION Privilege escalation is the increase in rights; PAM governs privileged identities and sessions across the lifecycle.

Service Accounts and Machine Identities

Easy definition: Service accounts, API identities, certificates, workloads, robots, and agents authenticate non-human processes and often hold powerful, long-lived access.

When it matters: Applications, scheduled jobs, cloud, CI/CD, databases, OT, automation, and integrations.

THINK LIKE A MANAGER Inventory every machine identity, assign a human owner and purpose, use workload identity or managed credentials, rotate secrets, constrain login and scope, monitor behavior, and retire promptly.

EXAM TRAPS

- Marking passwords “never expire.”
- Allowing interactive login for a service account without need.
- Sharing one service identity across unrelated applications.
- Embedding secrets in code or images.
- Ignoring ownership when an application team dissolves.

QUICK DISTINCTION Human accounts represent people; service accounts represent processes. Both require identity, least privilege, accountability, monitoring, and lifecycle control.

5.6 Implement Authentication Systems

Centralized Authentication: RADIUS, TACACS+, and Kerberos

Easy definition: RADIUS commonly provides network AAA, TACACS+ is often used for network-device administration with separated AAA functions, and Kerberos uses tickets and symmetric cryptography for domain authentication.

When it matters: VPN, wireless, NAC, network administration, enterprise SSO, and directory environments.

THINK LIKE A MANAGER Select protocols from use case and risk, protect shared secrets and servers, build resilience and time synchronization, and retain accountable authorization and logs.

EXAM TRAPS

- Assuming RADIUS encrypts the entire packet in every form.
- Confusing TACACS+ with a general user directory.
- Sending Kerberos passwords across the network; tickets are used instead.
- Ignoring clock synchronization in Kerberos.
- Treating centralized authentication failure as a reason for permanent local shared accounts.

QUICK DISTINCTION RADIUS is common for network access; TACACS+ for device administration; Kerberos provides ticket-based authentication within a realm/domain.

Kerberos Components and Tickets

Easy definition: Kerberos uses a Key Distribution Center containing an Authentication Service and Ticket-Granting Service; a TGT obtains service tickets without repeatedly presenting the user's long-term secret.

When it matters: Windows domains, enterprise authentication, delegation, service identities, and ticket attacks.

THINK LIKE A MANAGER Protect domain controllers, privileged endpoints, service-account keys, delegation, and time; monitor abnormal ticket issuance and use.

EXAM TRAPS

- Confusing TGT with a service ticket.
- Assuming Kerberos provides authorization to the application.
- Ignoring service principal names and delegation risk.
- Believing tickets cannot be stolen or forged.
- Failing to secure recovery and administrative paths to the KDC.

QUICK DISTINCTION AS issues a TGT; TGS uses the TGT to issue a service ticket; the service validates that ticket and applies authorization.

Authentication System Resilience and Recovery

Easy definition: Authentication is a critical dependency requiring redundancy, protected recovery, emergency access, monitoring, capacity, and tested failure behavior.

When it matters: Identity providers, directories, MFA, certificate services, federation, remote access, and cloud.

THINK LIKE A MANAGER Design authentication as a tier-zero service: isolate administration, diversify critical

dependencies, test outage procedures, and tightly govern break-glass access.

EXAM TRAPS

- Building redundant servers in one failure domain.
- Failing open broadly when identity services are unavailable.
- Keeping emergency credentials that are untested, shared, or unmonitored.
- Ignoring DNS, time, certificates, network, and device dependencies.
- Testing login but not revocation during outages.

QUICK DISTINCTION High availability keeps normal authentication working; break-glass provides controlled exceptional access when normal mechanisms fail.

Authentication Attacks and Defenses

Easy definition: Credential attacks include guessing, spraying, stuffing, phishing, MFA fatigue, replay, token theft, session hijacking, pass-the-hash, and adversary-in-the-middle techniques.

When it matters: Authentication design, monitoring, incident response, user education, and privileged access.

THINK LIKE A MANAGER Reduce shared secrets, use phishing-resistant MFA, rate-limit and detect abuse, protect endpoints and sessions, and make recovery at least as strong as normal login.

EXAM TRAPS

- Responding to password spraying only with stronger complexity rules.
- Assuming MFA stops session-cookie theft.
- Blocking one IP when attacks are distributed.
- Focusing on login and ignoring enrollment, reset, consent, token, and session attacks.
- Blaming users without improving resistant technology and reporting.

QUICK DISTINCTION Credential theft defeats authentication input; session theft bypasses repeated login; authorization and continuous session controls remain necessary.

Cross-Domain Exam Traps for Domain 5

Who Decides and Who Implements?

Decision or action	Likely accountable role	Trap to avoid
Approve business access	Resource/data owner or delegated manager	Administrator should not invent business need.
Establish identity	HR/sponsor/authoritative identity process	Possession of an email address is not proofing.
Issue and manage credentials	IAM/security operations	Credential issuance is not authorization.
Define role permissions	Business and resource owners with IAM	Technical groups should not become ownerless roles.
Review access	Accountable owner/manager	Security can facilitate but may lack business context.
Accept toxic combination risk	Authorized risk owner	IAM administrator should not accept business risk.
Provision/deprovision targets	IAM and system custodians	Workflow completion must be reconciled with actual state.

What Happens First?

- New person or entity: establish authoritative identity and sponsor before issuing credentials or access.
- New application: identify resource owners, data, roles, operations, conflicts, assurance, and lifecycle requirements before selecting authentication.
- Access request: verify business need, owner approval, least privilege, and separation of duties before provisioning.
- Federation: define trust parties, assurance, attributes, protocols, token rules, lifecycle, incident response, and termination.
- Role transfer: remove incompatible or obsolete access while adding the new approved role.
- Termination: trigger timely revocation of accounts, sessions, tokens, badges, certificates, remote access, and third-party access.
- Authentication incident: contain compromised credentials and sessions, preserve evidence, identify scope, and fix enrollment or recovery weaknesses.

ROOT-CAUSE TRAP If users have excessive access, stronger MFA is not the primary fix. MFA strengthens authentication; excessive access requires authorization redesign, owner review, role cleanup, provisioning correction, and timely deprovisioning.

Domain 5 Rapid Review

ONE-SENTENCE DOMAIN SUMMARY Establish trustworthy identities, authenticate them at appropriate assurance, authorize only owner-approved least privilege, govern federation and sessions, review effective access, and revoke every human and machine identity promptly when need changes.

High-Yield Distinctions

Concept A	Concept B	Fast distinction
Identification	Authentication	Claims an identity vs. verifies the claim
Authentication	Authorization	Verifies identity vs. determines permitted actions
Identity proofing	Authentication	Establishes identity initially vs. verifies later claims
MFA	Two-step verification	Different factor types vs. possibly two checks of one type
Group	Role	Administrative collection vs. business job function
SSO	Federation	One-login experience vs. cross-domain trust arrangement
SAML	OAuth 2.0	Authentication assertions/SSO vs. delegated API authorization
OAuth 2.0	OpenID Connect	Delegated authorization vs. authentication identity layer
DAC	MAC	Owner discretion vs. centrally enforced labels
RBAC	Rule-based	Job-role permissions vs. system rules/conditions
RBAC	ABAC	Role assignment vs. multi-attribute policy
PDP	PEP	Makes decision vs. enforces decision
Provisioning	Reconciliation	Initiates state vs. verifies actual state
JIT access	Step-up authentication	Temporary authorization vs. stronger proof
FAR	FRR	Unauthorized accepted vs. authorized rejected

Final Manager-Mindset Checklist

- Has identity been established through an authoritative, risk-appropriate proofing process?
- Who owns the resource and approved the business need?
- Is authentication strength appropriate, phishing-resistant where warranted, and recovery equally protected?
- Does authorization enforce least privilege, need-to-know, separation of duties, and appropriate context?
- Are groups, roles, rules, attributes, and exceptions understandable and owned?
- Are federation assertions, tokens, scopes, mappings, keys, and trust termination governed?
- Are sessions limited, protected, monitored, revalidated, and revocable?
- Do joiner, mover, and leaver events propagate to every target, credential, token, badge, and third party?
- Are privileged and machine identities inventoried, time-bound where possible, rotated, monitored, and owned?
- Does reconciliation and access review prove that actual access matches approved intent?

Source and Scope Note

Coverage is aligned to the ISC2 CISSP Certification Exam Outline effective April 15, 2024. This independent study aid uses original explanations and does not reproduce exam questions or official courseware. Official outline: <https://www.isc2.org/certifications/cissp/cissp-certification-exam-outline>